

Exercício 8 — Taxonomia CWE

Explique como a taxonomia CWE auxilia na avaliação de vulnerabilidades e no gerenciamento de riscos.

Quais são os benefícios de usar um sistema de classificação padronizado como o CWE?

8. Taxonomia CWE

O que é a Taxonomia CWE?

Taxonomia significa **classificação organizada**. A taxonomia CWE organiza as fraquezas de software em uma hierarquia estruturada — de categorias amplas até falhas técnicas específicas.

```
Pilar (mais amplo)
├─ Classe
│   └─ Base
│       └─ Variante (mais específico)
```

Exemplo:

CWE-664: Controle Impróprio de um Recurso	← Pilar
├─ CWE-400: Consumo Descontrolado de Recursos	← Classe
│ └─ CWE-770: Alocação Sem Limites	← Base
│ └─ CWE-789: Alocação de Memória	← Variante

Esta estrutura permite que as equipes trabalhem no nível adequado — alto nível para políticas, nível específico para correções de código.

Como Auxilia na Avaliação de Vulnerabilidades

1. Classificação Consistente

Quando um scanner encontra uma falha, ele a rotula com um ID CWE. Cada ferramenta, equipe e fornecedor fala a mesma linguagem — sem ambiguidade sobre que tipo de fraqueza foi encontrada.

2. Análise de Causa Raiz

Um CVE diz *o que quebrou*. O CWE por trás dele diz *por que quebrou*.

```
CVE-2017-9805 (violação Equifax via Apache Struts)
  |
  └─> CWE-502: Desserialização de Dados Não Confiáveis
        |
        └─> Causa raiz: a aplicação confiava
              cegamente em objetos serializados externos
```

Compreender o CWE evita que o mesmo erro apareça em outras partes do código.

3. Escopo da Avaliação

A taxonomia ajuda os avaliadores a decidir **o que procurar**. Em vez de testar aleatoriamente, selecionam as categorias CWE relevantes para o tipo de aplicação sendo avaliada (web, mobile, embarcado) e testam sistematicamente.

Como Auxilia no Gerenciamento de Riscos

Tarefa de Gestão de Riscos	Como a Taxonomia CWE Ajuda
Priorização	CWEs de nível superior (Pilares) sinalizam risco sistêmico em todo o código
Rastreamento de Tendências	Quais categorias CWE aparecem mais em nossas sprints? Indica problema de treinamento ou processo
Risco de Terceiros	Softwares de fornecedores podem ser avaliados com base em perfis CWE conhecidos

Tarefa de Gestão de Riscos	Como a Taxonomia CWE Ajuda
Conformidade	Regulamentações como PCI-DSS e OWASP ASVS mapeiam controles diretamente para categorias CWE
Trilha de Auditoria	IDs CWE criam um registro claro e padronizado do que foi avaliado e remediado

Benefícios de um Sistema de Classificação Padronizado

Para desenvolvedores

- Sabem exatamente que tipo de falha evitar — não apenas conselhos vagos como "escreva código seguro"
- Treinamento direcionado com base nos padrões CWE recorrentes em seu trabalho

Para equipes de segurança

- Comparar descobertas entre diferentes ferramentas e projetos usando os mesmos IDs
- Construir métricas: *"Reduzimos descobertas CWE-89 em 80% neste trimestre"*

Para a gestão

- Traduzir risco técnico em risco de negócio usando um padrão reconhecido
- Demonstrar diligência devida a auditores e reguladores

Para a indústria

- Fornecedores, pesquisadores e governos compartilham um vocabulário comum
- Ferramentas se integram entre si porque todas referenciam a mesma taxonomia

Resumo

A taxonomia CWE transforma o mundo caótico das fraquezas de software em um catálogo organizado, pesquisável e acionável. Sem ela, cada equipe reinventaria a roda — e repetiria os mesmos erros que outros já documentaram.